

CSE 331: Computer Security Fundamentals

Spring 2026

Worms and Rootkit

Amir Rahmati
Xinrui Yu



Stony Brook Institute
at Anhui University

安徽大學紐約石溪學院

What's a Worm?

- **Self-Replication and Propagation:**

Create copies of themselves and spread autonomously across networked devices.

- **Exploitation of Vulnerabilities:**

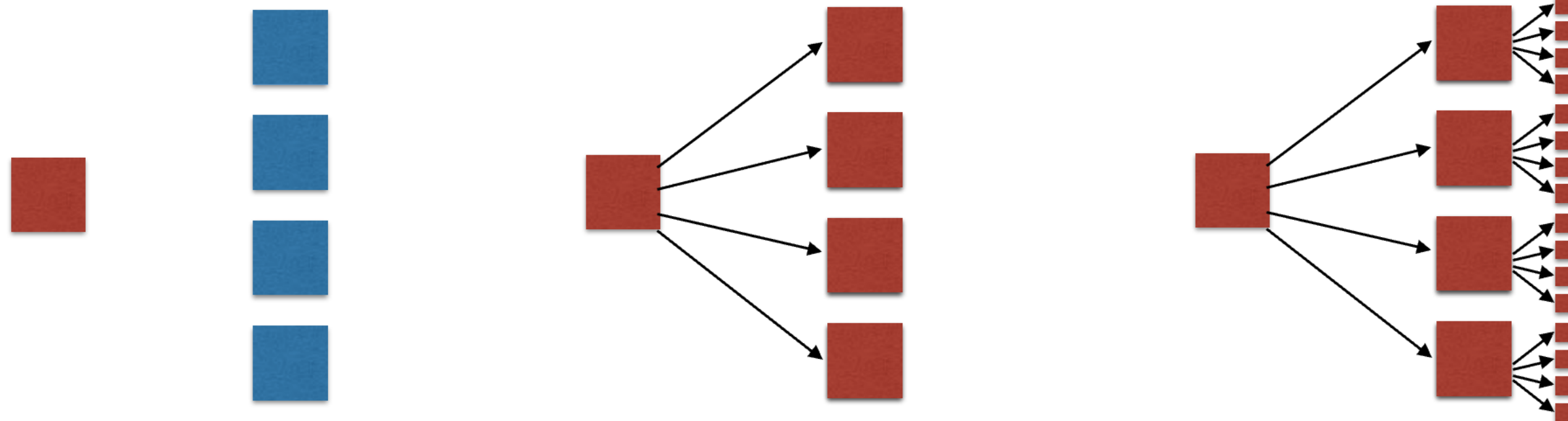
Worms exploit weaknesses in software, hardware, etc, to gain access to systems.

- **Can Carry a Payload:**

While some worms merely consume network resources, others can carry a malicious payload like malware.

Self-Propagation

- The goal is to spread as quickly as possible
- The key is parallelization



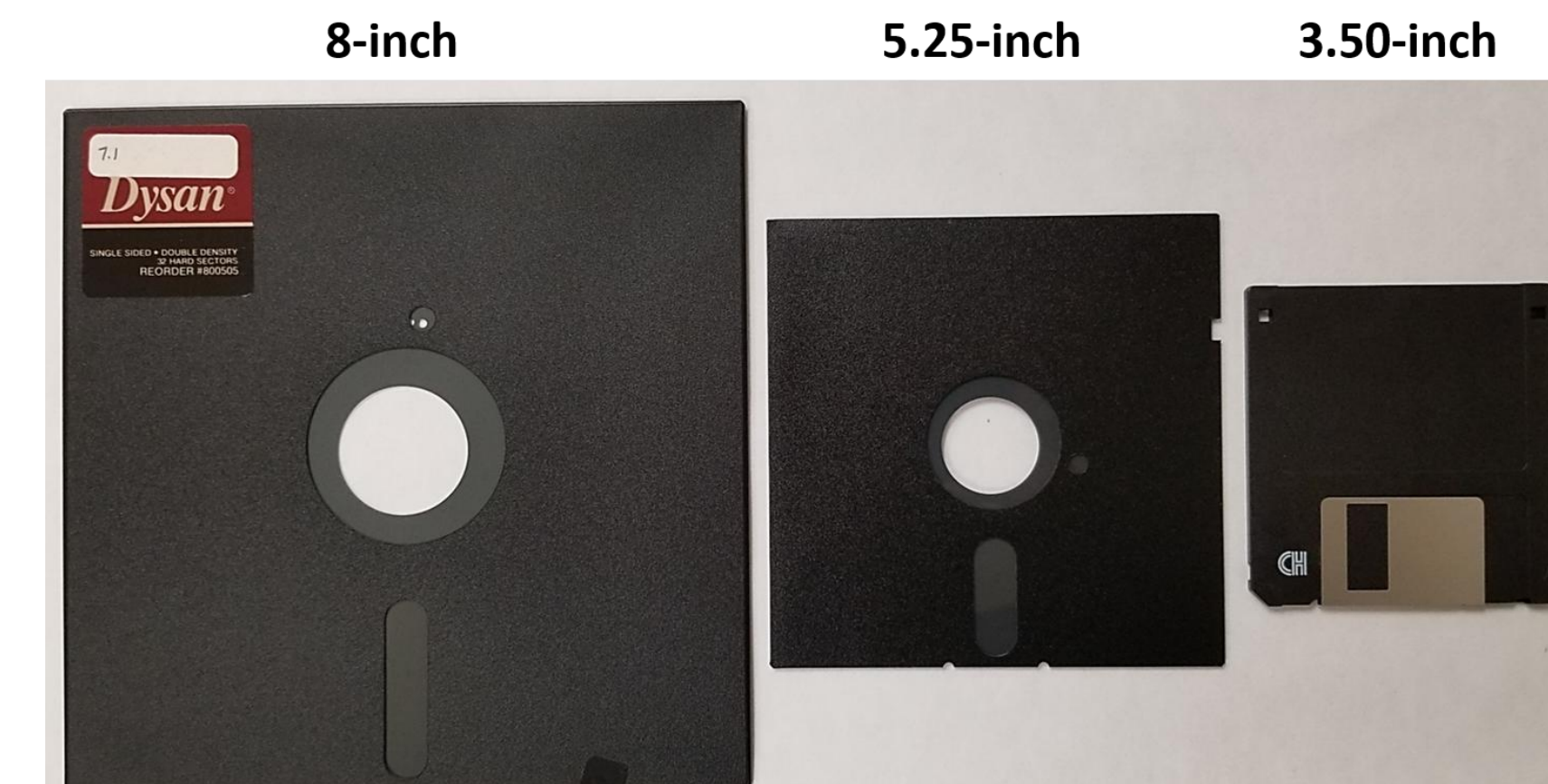
Propagation

- (1) **Targeting**: how does the worm **find new prospective victims**?
- (2) **Exploit**: how does the worm get code to **automatically run**?

BRAIN

First IBM PC virus (1987)

- **Propagation method**
 - Not networked; copies itself into the boot sector of a floppy disc
 - Intercepts disk read requests for 5.25" floppy drives
 - Sees if the 5th and 6th bytes of the boot sector are 0x1234
 - If so, then it's already infected, otherwise, infect it
- **Payload**
 - Nothing really; goal was just to spread (to show off?)
 - However, it served as the template for future viruses



Morris Worm (1988)



- Created by Cornell University CS student, Robert Morris (23)
- Propagated across machines (too aggressively, thanks to a bug)
- One way it propagated was a buffer overflow attack
- End result: \$10-100M in damages, probation, community service
- Later Morris became a tenured professor at MIT

CodeRed (2001)

- Propagation: Exploited an overflow in the MS-IIS (Microsoft Internet Information Services) server
- Payload 1: website defacement
- Payload 2: time bomb
 - Day of month 1-20: Spread
 - Day of month 20+: Attack (flood 198.137.240.91 = whitehouse.gov)
- 300,000 machines infected in 14 hours

Worm Propagation

- Goal: spread your virus as widely and as quickly as possible
- Mechanisms:
 - `attack(IP address)`
 - tries to connect to and exploit MS-IIS (if it happens to be running on that IP address)
 - `spread(code, state, IP addr)`
 - copies over the code to the IP address, and executes it
- Question:

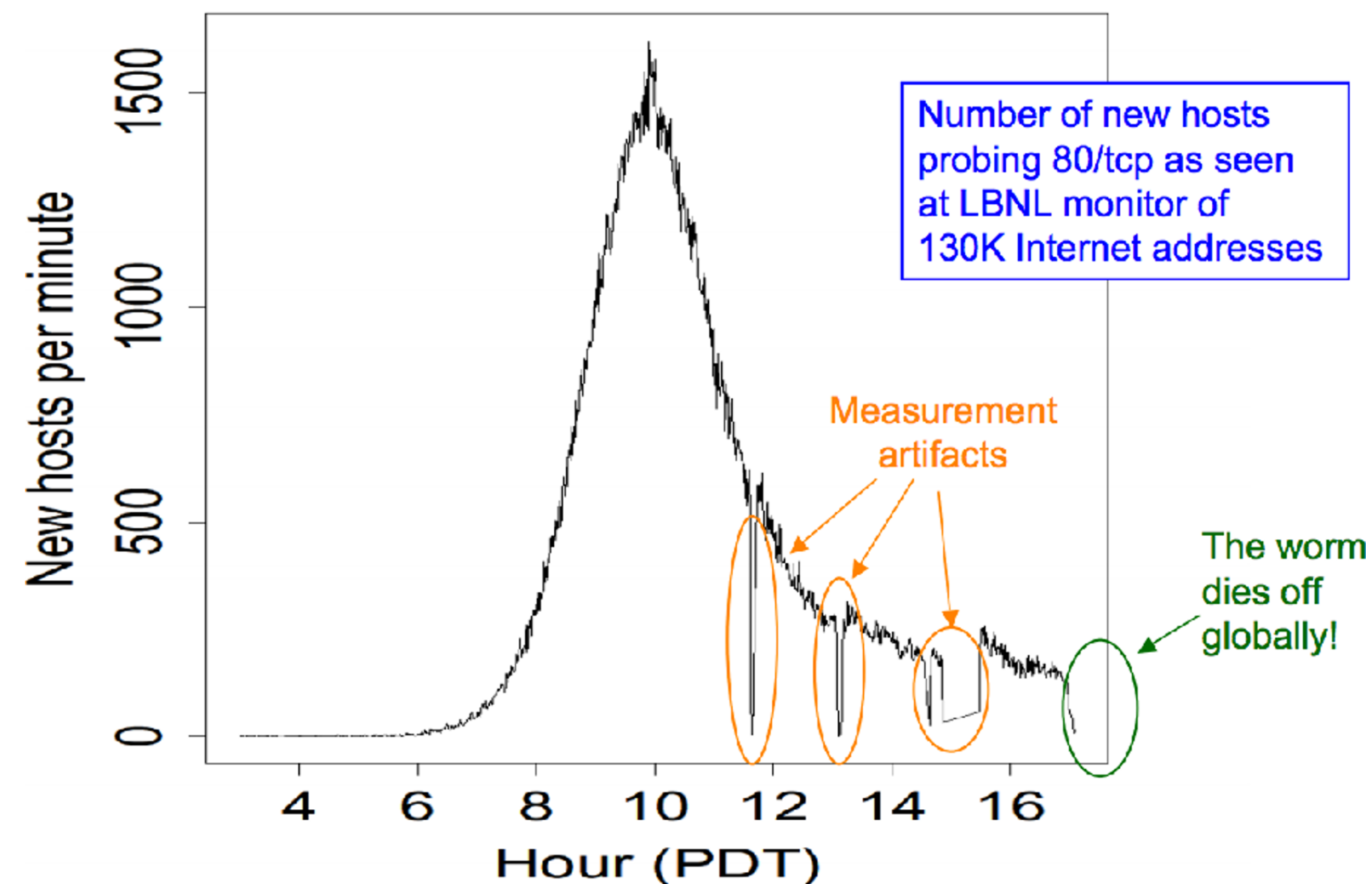
What IP addresses do you choose? What do your “children” choose?

CodeRed Propagation (v1)

- Spread by randomly scanning the entire 32-bit IP address space
 - IPaddr = pseudorandom 32-bit number
 - Try attack(IPaddr)
 - Repeat
- This is a very common but not fundamental worm technique
- Each instance of the worm used the same random number seed
- Linear increase because of repeated infections

Code Propagation V2 (1 week later)

- Whitehouse.gov changed its IP address
- This caused CodeRed to die for date ≥ 20 th of the month
- .. Author didn't test the code: it was buggy!
- But with this revision, the random number generator was seeded properly!



Modeling Worm Spread

Increase in # infectibles per unit time

$$\frac{dI}{dt} = \beta \cdot I \cdot \frac{S}{N}$$

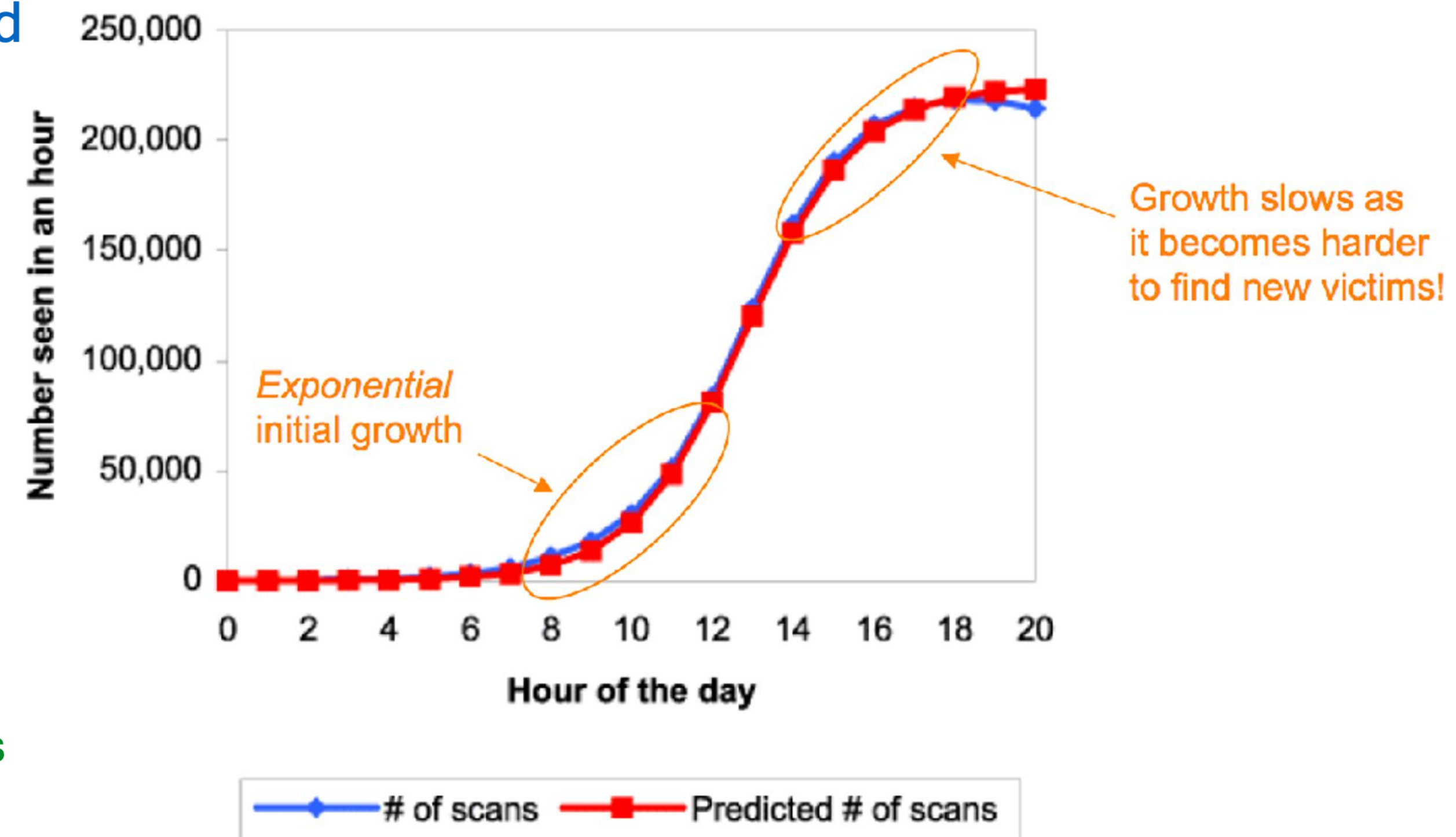
Fraction of contacts expected to succeed

Total attempted contacts per unit time

Rewriting using $i(t) = I(t) / N$ and $S = N - I$:

$$\frac{di}{dt} = \beta \cdot i \cdot (1-i) \quad \rightarrow \quad i(t) = \frac{e^{\beta t}}{1 + e^{\beta t}}$$

Fraction infected grows as a *logistic*

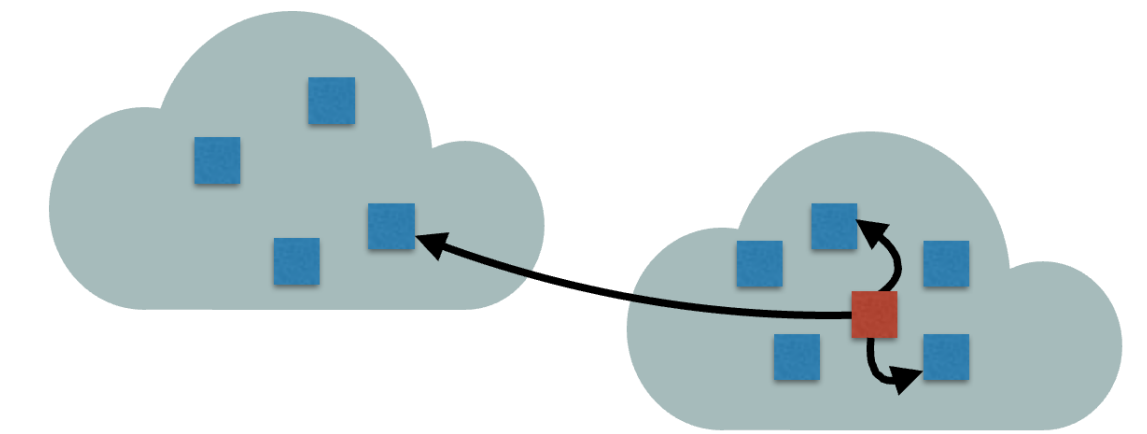


CodeRed Spread

- Large-scale monitoring found 360K systems were infected with CodeRed on July 19 (<13 hours)
- That night (the 20th) the worm died due to bug
- Successfully managed to restart itself Aug 1
 - ... and each successive month for years to come

Better Worms

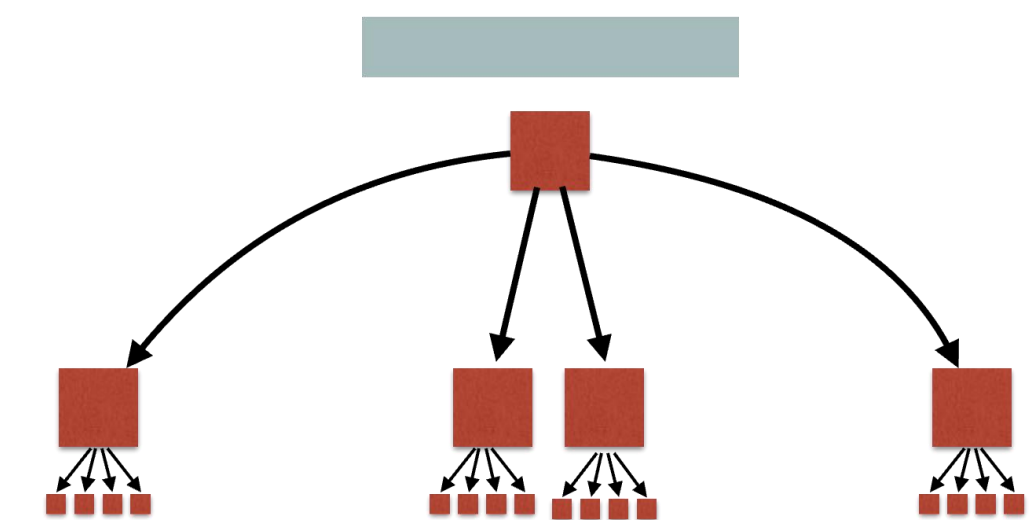
- Key challenge:
 - Coordinating action across distributed hosts
- Localized scanning:
 - Preferentially hosts with similar IP addresses
- Hit-list scanning
 - Start with a list of likely-successful targets
- Permutation scanning
 - Break up the work deterministically



$Pr = 3/8$ Random IP address in same /16

$Pr = 4/8$ Random IP address in same /8

$Pr = 1/8$ Random IP address



Quickly build an initial set of bots to “get off the ground”

Permuted list of IP addresses

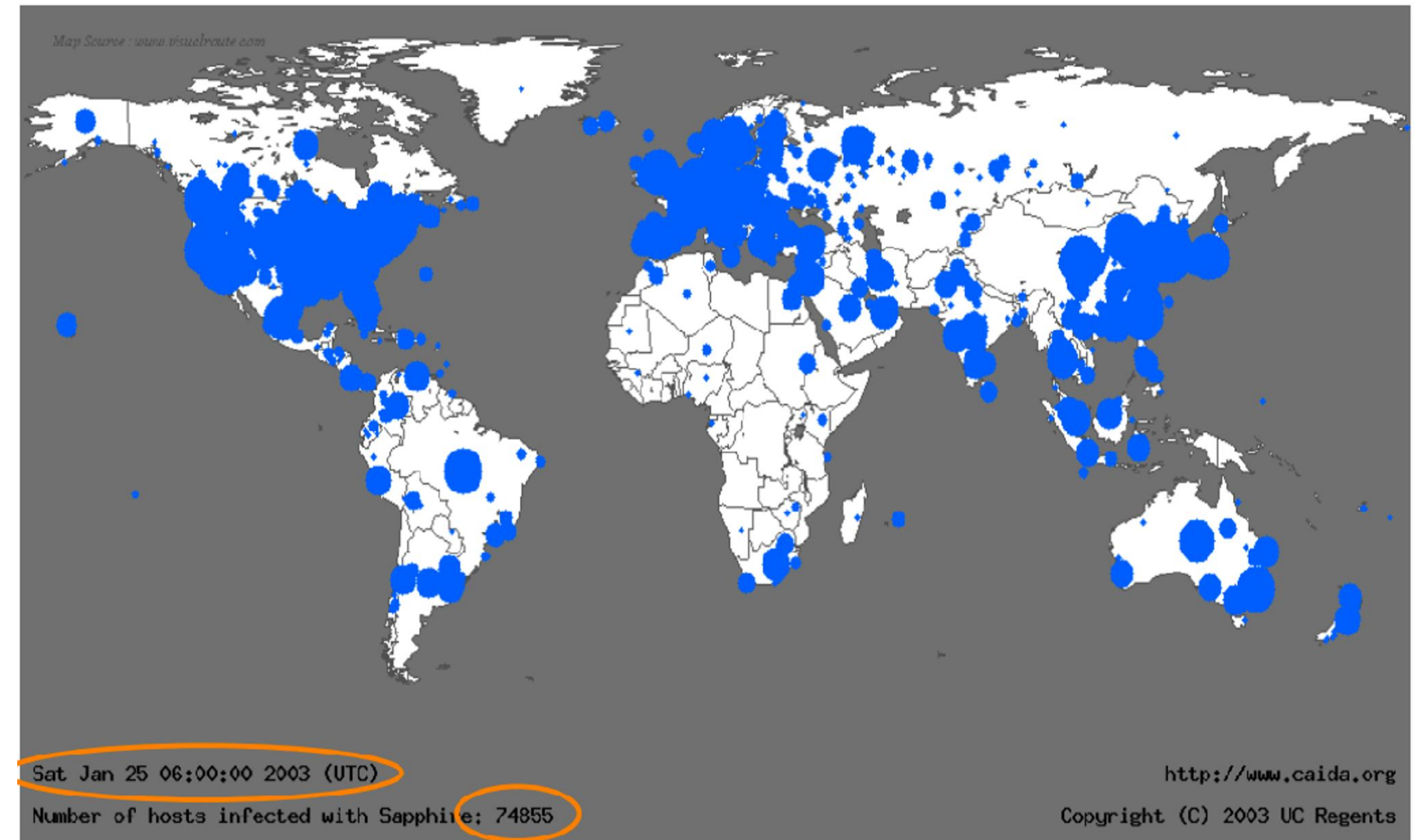
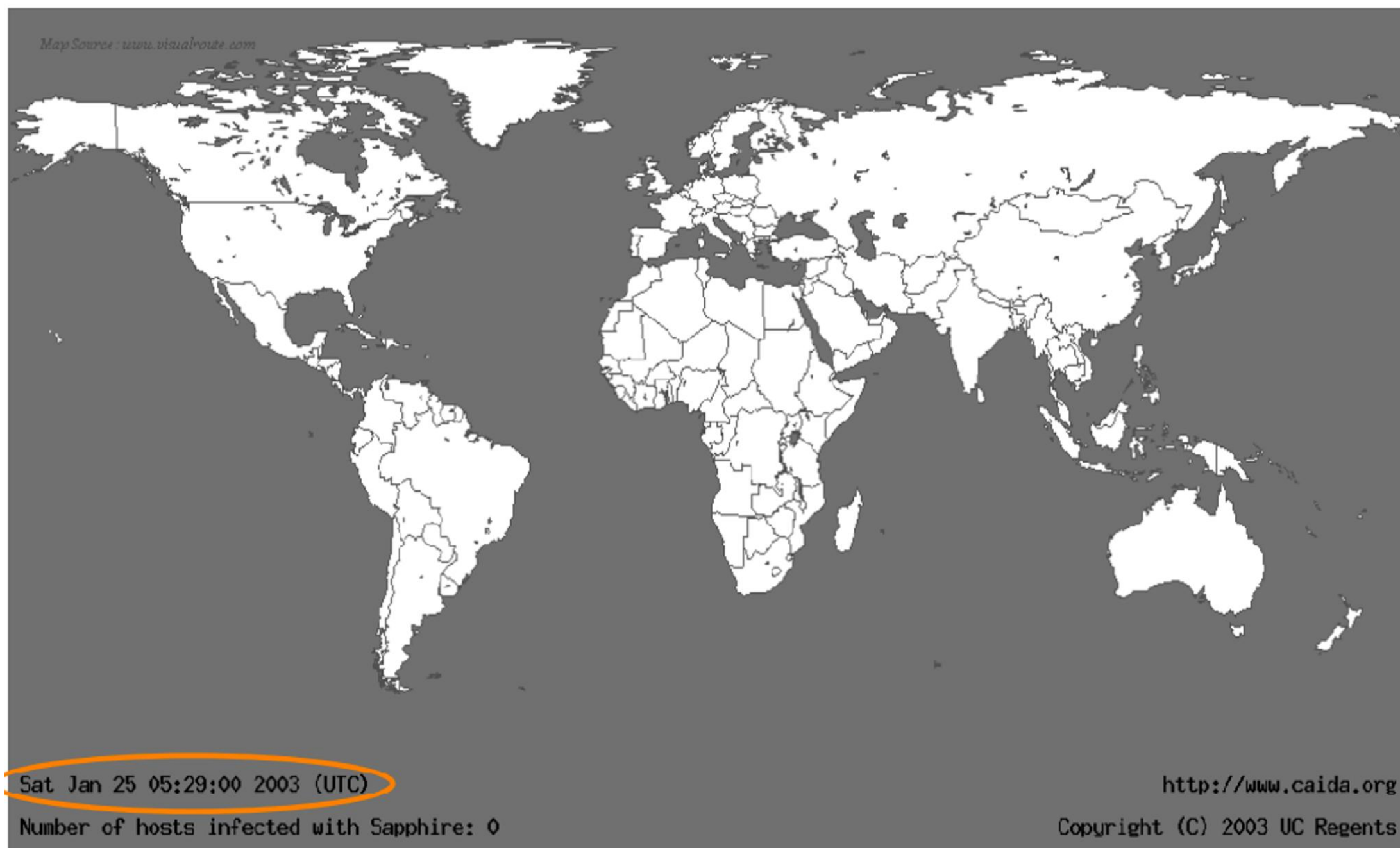


Start at a random seed; iteratively attack

When you reach an already-attacked node, re-seed

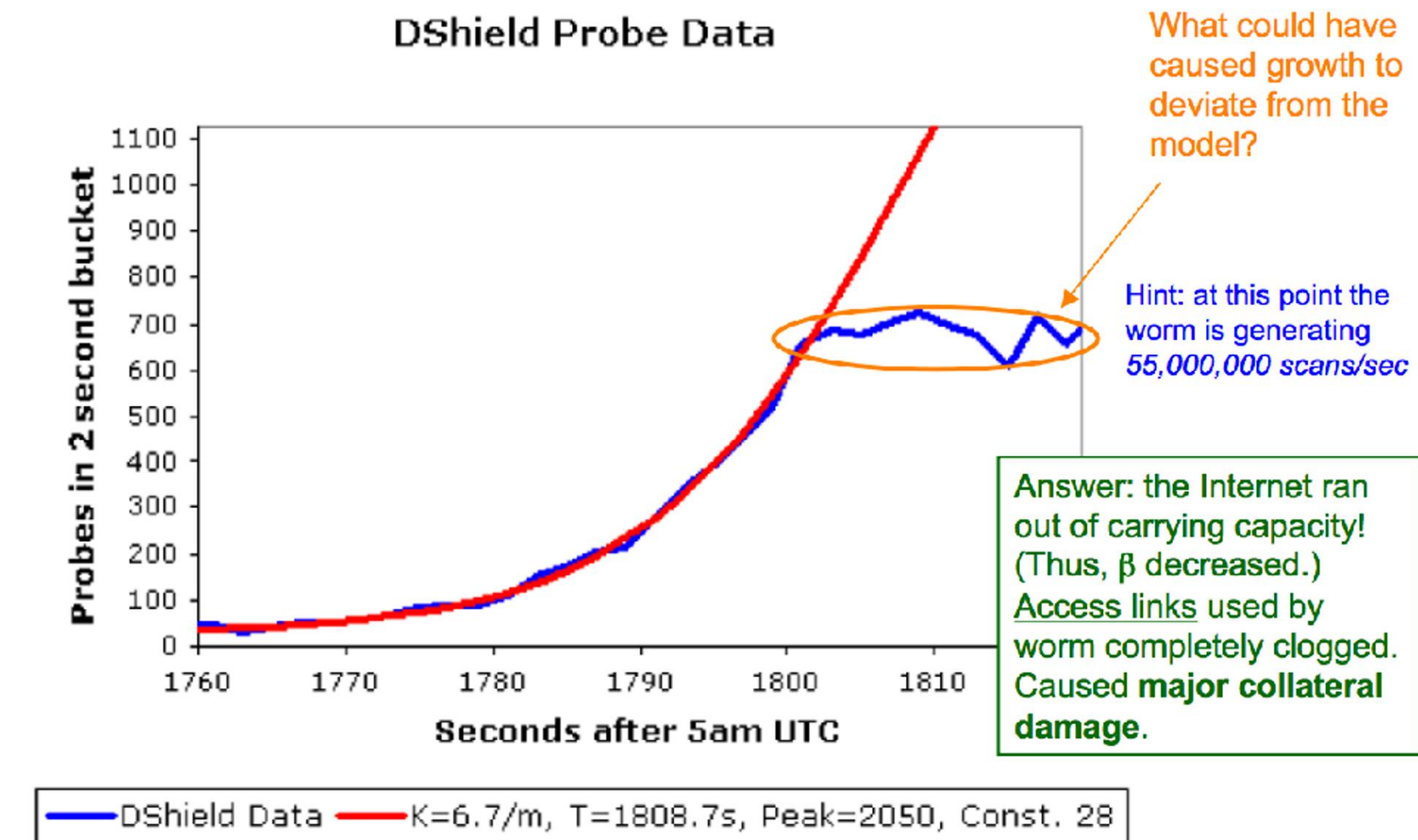
SQL Slammer (2003)

- Exploited an overflow in the MS-SQL server
- 75,000 machines infected in 10 minutes



SQL Slammer (2003)

- Slammer exploited connectionless UDP service, rather than connection-oriented TCP
- Entire worm fit in a single packet!
- Infected 75k+ hosts in < 10 minutes
- At its peak, doubled ever 8.5 seconds



warhol worm: Can theoretically infect every single vulnerable computer on the Internet in 15 minutes

How can we measure Worm Activity?

- Idea: Exploit the fact that worms indiscriminately scan

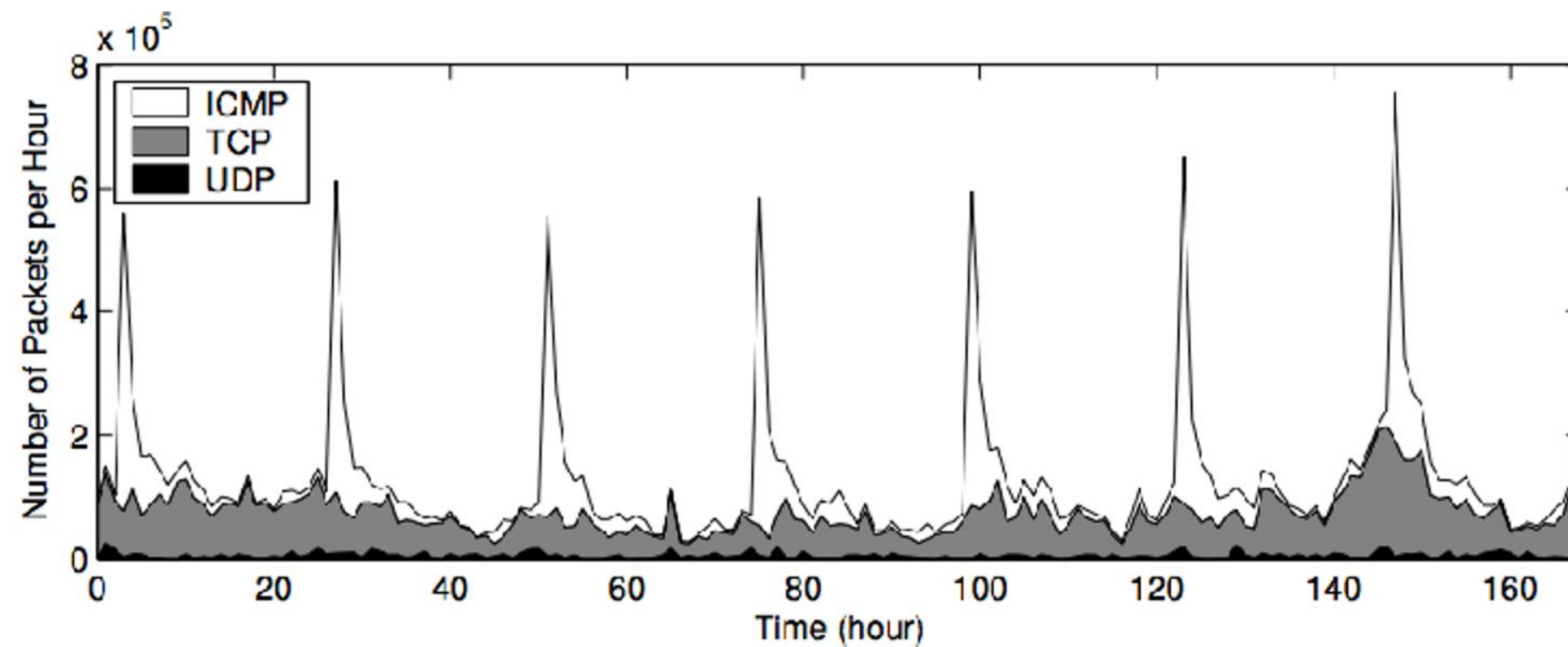
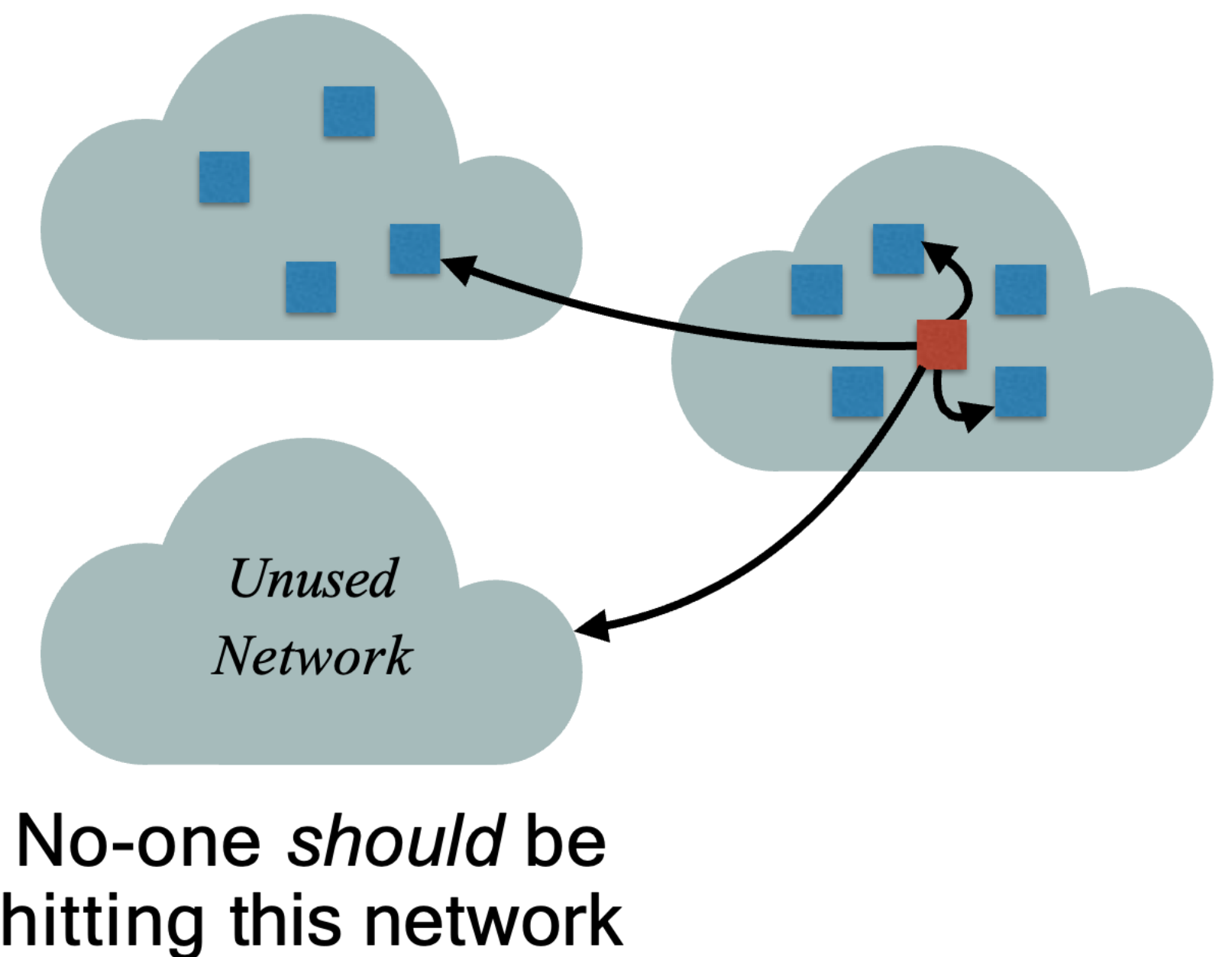


Figure 6: Number of background radiation packets per hour seen at LBL



Rootkits

- Malicious code that hides from discovery
- **Ways to hide**
 - By intercepting system calls, patching the kernel, etc.
 - Often effectively done by a man in the middle attack
- **Rootkit revealer**
 - analyzes the disk offline, and compares

Sony XCP Rootkit (2005)

- Goal: keep users from copying copyrighted material
- How it worked:
 - Loaded thanks to autorun.exe on the CD
 - Intercepted read requests for its music files
 - If anyone but Sony's music player is accessing them, then garble the data
 - Hid itself from the user (to avoid deletion)
- How it messed up
 - Morally: violated trust
 - Technically:
 - Hid all files that started with "\$sys\$"
 - The uninstaller did not check the integrity of the code it downloaded, and would not delete it afterwards.

STUXNET (2010)

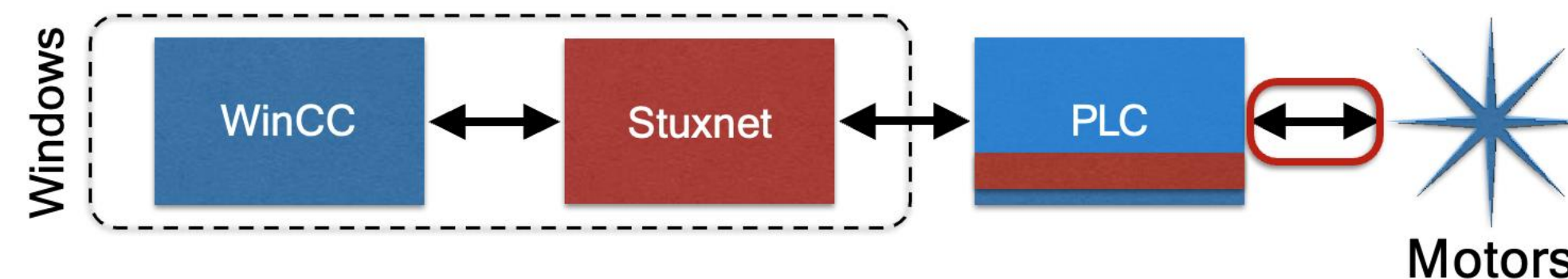
- Virus in that it initially spread by infected USB stick
- Once inside a network, it acted as a worm, spreading quickly
- Exploited four zero-day exploits (zero day after patch)
- Rootkit: installed signed device drivers
 - Thereby avoiding user alert when installing
 - Signed with certificates stolen from two Taiwanese CAs

STUXNET (2010)

- Do nothing
- Unless attached to particular models of frequency converter drives that operate at 807-1210Hz
 - like those in Iran and Finland
 - .. those ones that are used to operate centrifuges
 - .. for producing enriched uranium for nuclear weapons
- In which case, slowly increase the freq to 1410Hz
 - enough to break the centrifuge
 - .. all the while sending “looks good to me” readings to the user
 - .. then drop back to normal range

STUXNET (2010)

- Targets industrial control systems by overwriting programmable logic boards
- Man-in-the-middle between Windows and Siemens control systems; looked like it was working properly to the operator



- In reality, it sped up and slowed down the motors
- Result: Destroy 1k out of 5k nuclear centrifuges
- First prominent example of cyber warfare

Grey Zone of Computer Security

- Technological arms race
- Started off innocuously, capable by only a few very clever people
- But viruses have become commoditized
 - No longer purely of academic interest
 - Economic pursuits (zero-day markets)
 - Cyber warfare